Portkey key management guidance (WIP)

This guidance focuses creating granular, distinct keys that will enable fine-grained tracking and management.

Main principles

Principle	Guidance	Rationale
Granular separation	**Do not share keys.** Every application in every environment (e.g., Development, Staging, Production) must use its own unique Portkey API Key. This is the most critical principle for governance.	**Error isolation:** Prevents errors across multiple applications from being untraceable, allowing you to instantly isolate which application is failing
Environment isolation	**Create separate keys** for dev, staging and production environments.	Allows for complete separation of usage and security profiles between non-production and production environments. You care more about errors in production, but less so in dev.
Principle of least privilege	**Limit the provisioning** of API Keys to only the Workspaces that absolutely need them. Revoke access immediately if a key is compromised or no longer needed	Minimises the impact of a compromised key
Governance and control	Leverage Portkey's workspace	Controls costs and prevents unexpected

	provisioning to attach explicit **budget and rate limits (and auto expire if relevant)** to each key's usage, set with a weekly or monthly reset period. Set budget alert thresholds (80% of budget limit reached) to receive notifications before limits are reached	spikes in spend
Guardrails	Attach specific **Guardrails**/configs to distinct API Keys. E.g. a key used in Prod requires stricter guardrails than a key used for development or testing	Ensures that models are used consistently and within approved guidelines
Security	**Never hardcode Portkey API keys** directly into source code. Use a secure method like environment variables or secret stores [do we have anything atm?]	Protects credentials from being exposed in the event of a breach
Audits and rotation	Implement a regular **Key Rotation** policy (e.g. quarterly). Regularly **audit** key access and usage logs to detect and remove unnecessary access	Ensures compliance

Portkey key naming conventions (API Keys)

For readability, we recommend the following format:

<BUSINESS UNIT>-<PRODUCT>-<SUB-PRODUCT/FEATURE>-<ENVIRONMENT>-<PURPOSE>

Component	Description	Example
BUSINESS UNIT	The primary business unit or domain	GSS, IT&DIGITAL, CP R&D
PRODUCT	The specific application or service using the key	LORYN
SUB-PRODUCT/FEATURE (Optional)	Specific sub-product or feature	CHATBOT, SALES ASSISTANT
ENVIRONMENT	The deployment stage (essential for isolation)	DEV, STG, UAT, PROD
PURPOSE (Optional)	A specific purpose or user if necessary	DEFAULT, HIGH-THROUGHPUT

Examples:

GSS-LORYN-CHATBOT-PROD-DEFAULT

FINANCE-INVOICING-UAT-DEFAULT